

9 Authentication & Authorization

📁 المحتويات

1. [Authentication مقدمة عن] (#authentication-مقدمة-عن)
2. [Laravel Breeze Setup] (#laravel-breeze-setup)
3. [Authentication System] (#authentication-system)
4. [Authorization & Gates] (#authorization--gates)
5. [Policies] (#policies)
6. [Middleware Authentication] (#middleware-authentication)
7. [Password Management] (#password-management)
8. [Remember Me & Sessions] (#remember-me--sessions)
9. [API Token Authentication] (#api-token-authentication)
10. [أمثلة - عملية] (#أمثلة -عملية)

Authentication مقدمة عن

Authentication ما هو

****Authentication**** = التحقق من هوية المستخدم (من أنت؟)
****Authorization**** = التحقق من صلاحيات المستخدم (ماذا يمكنك فعله؟)

...



...

Authentication و Authorization الفرق بين

Authentication	Authorization
من أنت؟	ماذا يمكنك فعله؟
التحقق من بيانات الدخول	التحقق من الصلاحيات
Login/Register	Permissions/Roles
`auth()->check()`	`Gate::allows()`

Laravel Breeze Setup

ما هو Laravel Breeze؟

****Laravel Breeze**** = نظام مصادقة بسيط وسريع جاهز للاستخدام يشمل:

- Login, Register, Logout
- Password Reset
- Email Verification
- Profile Management

التثبيت

```bash

# 1. تثبيت Breeze

composer require laravel/breeze --dev

# 2. تثبيت Scaffolding

php artisan breeze:install blade

# 3. تثبيت NPM Dependencies

npm install && npm run dev

# 4. تشغيل Migrations

php artisan migrate

```

الملفات التي يتم إنشاؤها

```

app/

├ Http/Controllers/Auth/

| └ AuthenticatedSessionController.php # Login

| └ RegisteredUserController.php # Register

| └ PasswordResetLinkController.php # Forgot Password

| └ ...

resources/

├ views/auth/

| └ login.blade.php

| └ register.blade.php

| └ ...

routes/

├ auth.php

# Authentication Routes

```

Authentication System

Login

****AuthenticatedSessionController.php:****

```php

use Illuminate\Http\Request;

use Illuminate\Support\Facades\Auth;

class AuthenticatedSessionController extends Controller

{

/\*\*

\* عرض صفحة Login

\*/

public function create()

{

return view('auth.login');

}

/\*\*

\* معالجة Login

\*/

public function store(Request \$request)

{

\$credentials = \$request->validate([

'email' => 'required|email',

'password' => 'required',

]);

if (Auth::attempt(\$credentials, \$request->boolean('remember'))) {

\$request->session()->regenerate();

return redirect()->intended('dashboard');

}

return back()->withErrors([

'email' => 'البيانات غير صحيحة',

])->onlyInput('email');

}

/\*\*

\* Logout

\*/

public function destroy(Request \$request)

{

```

 Auth::guard('web')->logout();

 $request->session()->invalidate();
 $request->session()->regenerateToken();

 return redirect('/');
 }
}
...

Register

RegisteredUserController.php:
```php
use App\Models\User;
use Illuminate\Support\Facades\Hash;
use Illuminate\Auth\Events\Registered;

class RegisteredUserController extends Controller
{
    public function create()
    {
        return view('auth.register');
    }

    public function store(Request $request)
    {
        $request->validate([
            'name' => 'required|string|max:255',
            'email' => 'required|string|email|max:255|unique:users',
            'password' => 'required|string|min:8|confirmed',
        ]);

        $user = User::create([
            'name' => $request->name,
            'email' => $request->email,
            'password' => Hash::make($request->password),
        ]);

        event(new Registered($user));

        Auth::login($user);

        return redirect('dashboard');
    }
}
...

```

التحقق من المستخدم

```php

```
// التحقق إذا كان مسجل دخول
if (auth()->check()) {
 // مسجل دخول
}
```

```
// التحقق إذا كان غير مسجل
if (auth()->guest()) {
 // غير مسجل
}
```

```
// الحصول على المستخدم الحالي
$user = auth()->user();
$user = Auth::user();
```

```
// الحصول ID المستخدم على
$id = auth()->id();
```

```
// في Blade
@auth
```

```
 مرحباً {{ auth()->user()->name }}
```

```
@endauth
```

```
@guest
```

```
 تسجيل الدخول
```

```
@endguest
```
```

Login يدوياً

```php

```
use Illuminate\Support\Facades\Auth;
```

```
// Login → Credentials
if (Auth::attempt(['email' => $email, 'password' => $password])) {
 // نجح
}
```

```
// Login → Remember Me
if (Auth::attempt($credentials, $remember = true)) {
```

```

 // نجح
}

// Login → User Model مباشرة
Auth::login($user);
Auth::login($user, $remember = true);

// Login لطلب واحد فقط
Auth::once($credentials);

// Login → ID
Auth::loginUsingId(1);

// Logout
Auth::logout();
```

---

## Authorization & Gates

### Gates ما هي؟

**Gates** = طريقة بسيطة للتحقق من الصلاحيات

### Gate تعريف

**app/Providers/AppServiceProvider.php**
```php
use Illuminate\Support\Facades\Gate;

public function boot(): void
{
 // Gate بسيط
 Gate::define('update-post', function (User $user, Post $post) {
 return $user->id === $post->user_id;
 });

 // Gate لل Admin
 Gate::define('access-admin', function (User $user) {
 return $user->role === 'admin';
 });

 // Gate (يمكنه كل شيء Admin) مع قبل التحقق
 Gate::before(function (User $user, string $ability) {
 if ($user->role === 'super-admin') {
 return true;
 }
 });
}

```

```

 }
 });
}
...

استخدام Gates

```php
use Illuminate\Support\Facades\Gate;

// في Controller
public function update(Request $request, Post $post)
{
    if (Gate::allows('update-post', $post)) {
        // يمكنه التحديث
        $post->update($request->validated());
    }

    if (Gate::denies('update-post', $post)) {
        abort(403);
    }

    // يرمي 403 تلقائياً أو استخدم authorize
    Gate::authorize('update-post', $post);

    $post->update($request->validated());
}

// في Blade
@can('update-post', $post)
    تعديل
@endcan

@cannot('update-post', $post)

    لا يمكنك التعديل

@endcannot

// باستخدام User Model
if ($user->can('update-post', $post)) {
    //
}

if ($user->cannot('update-post', $post)) {

```

```

//
}
```

Gates مقدمة

```php
// Gate مع عدة Parameters
Gate::define('update-comment', function (User $user, Post $post, Comment $comment) {
    return $user->id === $comment->user_id
        && $comment->post_id === $post->id;
});

// Gate بدون User (لـ Guest)
Gate::define('view-post', function (?User $user, Post $post) {
    if ($post->is_published) {
        return true;
    }

    return $user && $user->id === $post->user_id;
});

// استخدام
Gate::authorize('update-comment', [$post, $comment]);
```

Policies

Policies ما هي؟

معين Model كلاس منظم للصلاحيات الخاصة بـ **Policy**

إنشاء Policy

```bash
# إنشاء Policy
php artisan make:policy PostPolicy

# إنشاء Policy مع Model
php artisan make:policy PostPolicy --model=Post
```

app/Policies/PostPolicy.php

```php
is_published) {

```



```

        return true;
    }

    // صاحب المنشور فقط يمكنه رؤية المسودة
    return $user && $user->id === $post->user_id;
}

/**
 * إنشاء منشور جديد
 */
public function create(User $user): bool
{
    return $user->email_verified_at !== null;
}

/**
 * تحديث منشور
 */
public function update(User $user, Post $post): bool
{
    return $user->id === $post->user_id;
}

/**
 * حذف منشور
 */
public function delete(User $user, Post $post): bool
{
    return $user->id === $post->user_id;
}

/**
 * استعادة منشور محذوف
 */
public function restore(User $user, Post $post): bool
{
    return $user->id === $post->user_id;
}

/**
 * حذف منشور نهائياً
 */
public function forceDelete(User $user, Post $post): bool
{
    return $user->role === 'admin';
}
}

```

```
```
```

### ### تسجيل Policy

```
app/Providers/AppServiceProvider.php:
```

```
```php
```

```
use App\Models\Post;
use App\Policies\PostPolicy;
use Illuminate\Support\Facades\Gate;
```

```
public function boot(): void
{
    Gate::policy(Post::class, PostPolicy::class);
}
```

```
```
```

(يكتشف تلقائياً Laravel Auto-Discovery أو استخدم

```
```
```

```
app/Models/Post.php → app/Policies/PostPolicy.php
app/Models/Comment.php → app/Policies/CommentPolicy.php
```

```
```
```

### ### استخدام Policies

```
```php
```

```
// في Controller
```

```
public function update(Request $request, Post $post)
```

```
{
    // يرمي 403 تلقائياً) authorize() طريقة: 1
    $this->authorize('update', $post);

    $post->update($request->validated());
}
```

```
public function destroy(Post $post)
```

```
{
    // طريقة: 2 Gate::authorize()
    Gate::authorize('delete', $post);

    $post->delete();
}
```

```
public function show(Post $post)
```

```
{
    // طريقة: 3 can()
    if (auth()->user()->can('view', $post)) {
        return view('posts.show', compact('post'));
    }
}
```

```

    }

    abort(403);
}

// في Blade
@can('update', $post)
    تعديل
@endcan

@can('delete', $post)

    @csrf
    @method('DELETE')
    

@endcan

// في Route
Route::put('/posts/{post}', [PostController::class, 'update'])
    ->can('update', 'post'); // 'post' = route parameter name
...

### Policy Methods متقدمة

```php
class PostPolicy
{
 /**
 * يمكنه كل شيء (Admin) قبل كل التحقيقات
 */
 public function before(User $user, string $ability): ?bool
 {
 if ($user->role === 'super-admin') {
 return true;
 }

 return null; // استمر في التحقق العادي
 }

 /**
 * تحديث منشور مع شروط إضافية
 */
 public function update(User $user, Post $post): bool
 {

```

```

 // صاحب المنشور
 if ($user->id === $post->user_id) {
 return true;
 }

 // المشرف إذا لم يتم النشر
 if ($user->role === 'moderator' && !$post->is_published) {
 return true;
 }

 return false;
 }
}
```

---

## Middleware Authentication

### auth Middleware

```php
// في routes/web.php
Route::middleware('auth')->group(function () {
 Route::get('/dashboard', [DashboardController::class, 'index']);
 Route::resource('posts', PostController::class);
});

// في Controller
class PostController extends Controller
{
 public function __construct()
 {
 $this->middleware('auth');

 // محددة actions أو لا
 $this->middleware('auth')->only(['create', 'store', 'edit', 'update']);
 $this->middleware('auth')->except(['index', 'show']);
 }
}
```

### guest Middleware

```php
// للصفحات التي يمكن للضيوف فقط الوصول إليها
Route::middleware('guest')->group(function () {

```

```

Route::get('/login', [LoginController::class, 'create']);
Route::post('/login', [LoginController::class, 'store']);
Route::get('/register', [RegisterController::class, 'create']);
Route::post('/register', [RegisterController::class, 'store']);
});
...

verified Middleware

```php
// للصفحات التي تتطلب تأكيد البريد الإلكتروني
Route::middleware(['auth', 'verified'])->group(function () {
    Route::get('/premium', [PremiumController::class, 'index']);
});
...

### Custom Auth Middleware

```bash
php artisan make:middleware EnsureUserIsAdmin
...

app/Http/Middleware/EnsureUserIsAdmin.php:
```php
check() || auth()->user()->role !== 'admin') {
    abort(403, 'Unauthorized');
}

    return $next($request);
}
}
...

**app/Http/Kernel.php:**
```php
protected $middlewareAliases = [
 // ...
 'admin' => \App\Http\Middleware\EnsureUserIsAdmin::class,
];
...

الاستخدام:
```php
Route::middleware('admin')->group(function () {
    Route::get('/admin/dashboard', [AdminController::class, 'index']);
});
...

```

Password Management

Password Reset

يوفر نظام إعادة تعيين كلمة المرور Laravel Breeze:

...

1. يطلب إعادة التعيين → يرسل بريد User
2. يضغط على الرابط في البريد User
3. يدخل كلمة مرور جديدة User
4. يتم تحديث كلمة المرور

...

تغيير كلمة المرور

```php

use Illuminate\Support\Facades\Hash;

public function updatePassword(Request \$request)

{

    \$request->validate([  
        'current\_password' => 'required|current\_password',  
        'password' => 'required|string|min:8|confirmed',  
    ]);

    \$request->user()->update([  
        'password' => Hash::make(\$request->password),  
    ]);

    return back()->with('status', 'تم تحديث كلمة المرور');

}

...

### ### التحقق من كلمة المرور

```php

use Illuminate\Support\Facades\Hash;

// التحقق

if (Hash::check('plain-text-password', \$hashedPassword)) {

 // صحيحة

}

// في Validation

```
$request->validate([
    'current_password' => 'required|current_password',
]);
``
```

Password Hashing

```
```php
use Illuminate\Support\Facades\Hash;

// Hashing
$hashed = Hash::make('password');

// Check if needs rehash
if (Hash::needsRehash($hashed)) {
 $hashed = Hash::make('password');
}
``
```

---

## ## Remember Me & Sessions

### ### Remember Me

```
```php
// Login مع Remember Me
if (Auth::attempt($credentials, $remember = true)) {
    // يظل مسجلاً لمدة 5 سنوات
}

```

// في Form

☐

تذكرني

``

Session Management

```
```php
// إعادة توليد Session (منع Session Fixation)
$request->session()->regenerate();

// إلغاء Session
$request->session()->invalidate();

// إعادة توليد CSRF Token
$request->session()->regenerateToken();

```

```

// افعل الثلاثة - Logout عند
Auth::logout();
$request->session()->invalidate();
$request->session()->regenerateToken();
...

Session Configuration

config/session.php:
```php
return [
    'lifetime' => 120,           // Session lifetime بالدقائق
    'expire_on_close' => false,  // Session ينتهي عند إغلاق المتصفح
    'encrypt' => false,          // Session تشفير
    'driver' => env('SESSION_DRIVER', 'file'),
];
...

---

## API Token Authentication

### Laravel Sanctum

```bash
تثبيت Sanctum
composer require laravel/sanctum

نشر Migration
php artisan vendor:publish --provider="Laravel\Sanctum\SanctumServiceProvider"

تشغيل Migration
php artisan migrate
...

إنشاء Token

User Model:
```php
use Laravel\Sanctum\HasApiTokens;

class User extends Authenticatable
{
    use HasApiTokens, HasFactory, Notifiable;
}
...

```


****إنشاء Token:****

```php

// Token بسيط

```
$token = $user->createToken('token-name')->plainTextToken;
```

// Token مع Abilities (صلاحيات)

```
$token = $user->createToken('token-name', ['posts:create', 'posts:update'])
 ->plainTextToken;
```

```

استخدام Token

```php

// في routes/api.php

```
Route::middleware('auth:sanctum')->group(function () {
 Route::get('/user', function (Request $request) {
 return $request->user();
 });
});
```

```
Route::apiResource('posts', PostController::class);
});
```

```

****API Request:****

```bash

```
curl -H "Authorization: Bearer {token}" \
 -H "Accept: application/json" \
 https://example.com/api/user
```

```

التحقق من Abilities

```php

// في Controller

```
if ($request->user()->tokenCan('posts:create')) {
 // يمكنه إنشاء منشور
}
```

// Middleware

```
Route::post('/posts', [PostController::class, 'store'])
 ->middleware('auth:sanctum', 'abilities:posts:create');
```

```

أمثلة عملية

مثال 1: نظام مدونة بصلاحيات ###

****PostPolicy.php:****

```php

class PostPolicy

{

public function viewAny(?User \$user): bool

{

return true; // الجميع يمكنه عرض القائمة

}

public function view(?User \$user, Post \$post): bool

{

if (\$post->is\_published) {

return true;

}

return \$user && \$user->id === \$post->user\_id;

}

public function create(User \$user): bool

{

return \$user->email\_verified\_at !== null;

}

public function update(User \$user, Post \$post): bool

{

return \$user->id === \$post->user\_id;

}

public function delete(User \$user, Post \$post): bool

{

return \$user->id === \$post->user\_id

|| \$user->role === 'admin';

}

}

```

****PostController.php:****

```php

class PostController extends Controller

{

public function \_\_construct()

{

\$this->middleware('auth')->except(['index', 'show']);

}

```
public function index()
{
 $this->authorize('viewAny', Post::class);

 $posts = Post::where('is_published', true)
 ->latest()
 ->paginate(10);

 return view('posts.index', compact('posts'));
}

public function show(Post $post)
{
 $this->authorize('view', $post);

 return view('posts.show', compact('post'));
}

public function create()
{
 $this->authorize('create', Post::class);

 return view('posts.create');
}

public function store(StorePostRequest $request)
{
 $this->authorize('create', Post::class);

 $post = auth()->user()->posts()->create($request->validated());

 return redirect()->route('posts.show', $post);
}

public function edit(Post $post)
{
 $this->authorize('update', $post);

 return view('posts.edit', compact('post'));
}

public function update(UpdatePostRequest $request, Post $post)
{
 $this->authorize('update', $post);

 $post->update($request->validated());
}
```

```

 return redirect()->route('posts.show', $post);
 }

 public function destroy(Post $post)
 {
 $this->authorize('delete', $post);

 $post->delete();

 return redirect()->route('posts.index');
 }
}
...

```

### Roles و Permissions مثال 2: نظام

**\*\*User Model:\*\***

```php

```

class User extends Authenticatable
{
    public function hasRole(string $role): bool
    {
        return $this->role === $role;
    }

    public function isAdmin(): bool
    {
        return $this->role === 'admin';
    }

    public function isModerator(): bool
    {
        return $this->role === 'moderator';
    }

    public function canModerate(): bool
    {
        return in_array($this->role, ['admin', 'moderator']);
    }
}
...

```

****Gates:****

```php

// في AppServiceProvider

```

Gate::define('manage-users', function (User $user) {

```

```

 return $user->isAdmin();
 });

 Gate::define('moderate-posts', function (User $user) {
 return $user->canModerate();
 });

 Gate::define('edit-comments', function (User $user, Comment $comment) {
 return $user->id === $comment->user_id
 || $user->canModerate();
 });
 ...

 /**Middleware:**
    ```php
    class CheckRole
    {
        public function handle(Request $request, Closure $next, string $role)
        {
            if (!auth()->check() || !auth()->user()->hasRole($role)) {
                abort(403);
            }

            return $next($request);
        }
    }
    ...

    /**Routes:**
    ```php
 Route::middleware(['auth', 'role:admin'])->group(function () {
 Route::get('/admin/dashboard', [AdminController::class, 'index']);
 Route::resource('/admin/users', UserController::class);
 });

 Route::middleware(['auth', 'role:moderator'])->group(function () {
 Route::get('/moderate/posts', [ModerateController::class, 'posts']);
 });
 ...

```

### ### 3 مثال: API Authentication

```

 /**AuthController.php:**
    ```php
    class AuthController extends Controller
    {
        public function register(Request $request)

```

```

{
    $request->validate([
        'name' => 'required|string|max:255',
        'email' => 'required|email|unique:users',
        'password' => 'required|string|min:8|confirmed',
    ]);

    $user = User::create([
        'name' => $request->name,
        'email' => $request->email,
        'password' => Hash::make($request->password),
    ]);

    $token = $user->createToken('auth-token')->plainTextToken;

    return response()->json([
        'user' => $user,
        'token' => $token,
    ], 201);
}

public function login(Request $request)
{
    $request->validate([
        'email' => 'required|email',
        'password' => 'required',
    ]);

    if (!Auth::attempt($request->only('email', 'password'))) {
        return response()->json([
            'message' => 'Invalid credentials'
        ], 401);
    }

    $user = User::where('email', $request->email)->firstOrFail();

    $token = $user->createToken('auth-token')->plainTextToken;

    return response()->json([
        'user' => $user,
        'token' => $token,
    ]);
}

public function logout(Request $request)
{
    $request->user()->currentAccessToken()->delete();
}

```

```

        return response()->json([
            'message' => 'Logged out successfully'
        ]);
    }

    public function me(Request $request)
    {
        return response()->json($request->user());
    }
}
...

**routes/api.php:**
```php
Route::post('/register', [AuthController::class, 'register']);
Route::post('/login', [AuthController::class, 'login']);

Route::middleware('auth:sanctum')->group(function () {
 Route::post('/logout', [AuthController::class, 'logout']);
 Route::get('/me', [AuthController::class, 'me']);

 Route::apiResource('posts', PostController::class);
});
...

نصائح مهمة

أفضل الممارسات

1. **للمنطق المعقد Policies استخدم:**
    ```php
    // جيد - منظم
    $this->authorize('update', $post);

    // سيء - منطق في Controller
    if (auth()->user()->id !== $post->user_id) {
        abort(403);
    }
    ...

2. **Login عند إعادة توليد Session:**
    ```php
 // منع Session Fixation Attack
 $request->session()->regenerate();

```

```
```
```

3. ****دائماً Hash::make() استخدم****

```
```php
```

```
// آمن
```

```
Hash::make($password)
```

```
// خطر - لا تفعل
```

```
bcrypt($password) // قديم
```

```
password_hash() // لا تستخدم
```

```
```
```

4. ****تحقق من البريد الإلكتروني****

```
```php
```

```
Route::middleware(['auth', 'verified'])->group(function () {
```

```
 // routes
```

```
});
```

```
```
```

أخطاء شائعة

1. ****نسيان authorize():****

```
```php
```

```
// خطر
```

```
public function update(Request $request, Post $post)
```

```
{
```

```
 $post->update($request->validated());
```

```
}
```

```
// آمن
```

```
public function update(Request $request, Post $post)
```

```
{
```

```
 $this->authorize('update', $post);
```

```
 $post->update($request->validated());
```

```
}
```

```
```
```

2. ****بدون تحقق auth()->user() استخدام****

```
```php
```

```
// خطر - قد يكون null
```

```
$userId = auth()->user()->id;
```

```
// آمن
```

```
if (auth()->check()) {
```

```
 $userId = auth()->user()->id;
```

```
}
```



```
// أو
$userId = auth()->id();
```
```

3. ****إلغاء Session عند Logout:****

```
```php
```

```
// ناقص
```

```
Auth::logout();
```

```
// كامل
```

```
Auth::logout();
```

```
$request->session()->invalidate();
```

```
$request->session()->regenerateToken();
```

```
```
```

```
---
```

الخطوة التالية

بعد إتمام هذا الدرس، أنت الآن جاهز لـ

****10 الدرس: File Upload & Storage**

- File Upload

- Storage Configuration

- Image Processing

```
---
```

****إتعلم سعيد****